

DORA Gap Analysis Report

Musterbank GmbH — Digital Operational Resilience Act (EU 2022/2554)

Prepared by: Shingirai Marenga | ISO 27001 Lead Auditor | June 2026



Scope & Methodology

Entity in scope	Musterbank GmbH — regulated German financial institution (fictional portfolio entity)
Regulation	DORA Regulation (EU) 2022/2554 — in force 17 January 2025
Review methodology	ISO 27001 Lead Auditor control review; document review; process walkthrough
Frameworks	ISO 27001:2022, ISO 27005, ISO 31000, BaFin BAIT 2021, MaRisk AT7, NIST SP 800-30
Review date	June 2026 Reviewer: Shingirai Marenga, ISO 27001 Lead Auditor, CISM, CISSP

Disclaimer: This gap analysis was prepared for portfolio demonstration purposes using a fictional entity (Musterbank GmbH). DORA article references are based on Regulation (EU) 2022/2554 and applicable EBA/ESMA technical standards as of June 2026.

Executive Summary

This gap analysis assesses Musterbank GmbH's current ICT risk and security posture against the requirements of the Digital Operational Resilience Act (DORA, EU 2022/2554), which has been in force since 17 January 2025. The review was conducted using an ISO 27001 Lead Auditor methodology and maps existing ISO 27001 controls, BaFin BAIT obligations, and MaRisk requirements against each DORA pillar. This version has been updated to reflect the findings and risk ratings in the Musterbank ICT Risk Register (June 2026). All gap descriptions and priorities are consistent with Risk Register assessments.

The analysis covers all five DORA compliance pillars plus cross-cutting governance requirements, across 35 requirements in total. Of these, 2 are fully met, 21 are partially met with identified gaps, and 12 are missing — requiring immediate remediation. 8 critical findings require action before the next BaFin supervisory review.

Critical findings requiring immediate escalation to senior management / Risk Committee:

• ICT risk appetite and tolerance statement not board-approved (Art.6(8)) — KRI thresholds are unanchored across the entire Risk Register
• CIF (Critical or Important Function) identification not completed — Register of Information (Art.28) cannot be finalised without it
• DORA incident classification matrix absent; average BaFin notification time 5.2h against the 4-hour threshold (Art.17/19) — R-002
• BCP/DRP untested 18 months; 7 open 2024 actions; RTO/RPO unvalidated against DORA 4h threshold (Art.11) — R-015, Gross 25 Critical
• TLPT never conducted; Musterbank exceeds Art.26 thresholds; no TIBER-DE scope; BaFin not notified — R-004, Gross 16 Critical
• Register of Information does not meet EBA ITS RTS format; dependent on CIF completion (Art.28)
• No board-approved ICT third-party risk policy; vendor onboarding is ad hoc with no tiered classification (Art.28(1))

Pillar 1 — ICT Risk Management Articles 5–13

BAIT link: BAIT §2 (ICT governance), §4 (IT risk management), §5 (information risk), §7 (BCM) **MaRisk link:** MaRisk AT 7.2 (IT operations), AT 7.3 (BCM), AT 2.2 (risk appetite)

DORA's ICT risk management pillar substantially overlaps with existing ISO 27001 ISMS controls and BaFin BAIT requirements. The principal gaps are: the absence of a board-approved ICT risk appetite statement (Art.6(8) — Critical); BCP/DR untested 18 months with RTO/RPO unvalidated against the DORA 4-hour threshold (Art.12 — Critical, R-015 Gross 25); and the lack of a formally documented DORA-compliant framework. New additions include ICT capacity monitoring and data governance gaps identified during the Risk Register review.

Requirement	Article	ISO 27001	Status	Current Position	Remediation Action	Priority	Target
ICT risk management framework	Art. 5–6	Cl. 6.1, 8.2	■ Partial	ICT risk register maintained in Excel; quarterly Risk Committee review; no formally documented DORA-compliant framework.	Document framework per Art.6; obtain board approval for ICT risk appetite; evidence three-line model assignment.	High	Sep 2026
ICT asset classification & inventory	Art. 8	A.8.1, A.8.8	■ Partial	CMDB in ServiceNow; patching via Qualys; shadow IT not captured; no link to Register of Information.	Complete CMDB audit; classify per DORA criticality tiers; link to Register of Information; shadow IT tooling.	High	Oct 2026
ICT security policies & controls	Art. 9	A.5–A.9	✓ Met	ISO 27001 ISMS policy suite in place; annual review cycle; substantially covers Art.9 requirements.	Add explicit DORA Art.9 checklist to annual ISMS review; evidence alignment in policy headers.	Low	Dec 2026
ICT risk tolerance & appetite	Art. 6(8)	Cl. 6.1	✗ Missing	No board-approved ICT risk appetite or tolerance statement. KRI thresholds in Risk Register unanchored.	Draft ICT risk appetite statement; board approval by Sep 2026; cascade tolerance to Risk Register KRI thresholds.	Critical	Sep 2026
Business continuity & backup	Art. 12	A.17	✗ Missing	BCP/DR documented but untested 18 months; 7 open 2024 actions outstanding; RTO/RPO unvalidated vs DORA 4h threshold. Risk Register R-015 (Gross 25 — Critical; CE 0%).	Tabletop Q3-2026; full DR test Q4-2026; validate RTO ≤4h / RPO ≤1h; close 7 open actions; report to Risk Committee.	Critical	Oct 2026
ICT change management	Art. 9(4)	A.8.32	■ Partial	CAB in JIRA; rollback plan coverage 82%; emergency changes bypass CAB; 2 change incidents last month. R-013 (Gross 12 — High; CE 50%).	Mandatory rollback plans for 100% of changes; tighten emergency CAB gate; monthly trend reporting.	High	Aug 2026
ICT capacity & performance monitoring	Art. 9(3)	A.8.6	■ Partial	Datadog monitoring deployed; capacity reviews quarterly and manual; no automated threshold alerting.	Formalise capacity management plan; set automated threshold alerts; integrate with incident management.	Medium	Dec 2026
Data governance & integrity	Art. 9(3)	A.8.9, A.8.10	■ Partial	Data classification policy exists; data quality controls in ABACUS only; no enterprise data governance framework.	Implement data governance framework; document data lineage for BaFin reporting; enforce integrity controls.	Medium	Jan 2027

Pillar 2 — ICT Incident Management & Reporting Articles 17–23

BAIT link: BAIT §6 (incident management), §8 (security monitoring) **MaRisk link:** MaRisk AT 7.2 (IT incidents), AT 7.3 (BCM)

The most critical gap in this pillar is the absence of an automated DORA reporting workflow for the 4-hour initial notification to BaFin. The current manual process produces an average notification time of 5.2 hours — consistently breaching the regulatory threshold. Incident classification lacks a DORA-specific matrix aligned to EBA/ESMA ITS templates. These gaps are captured in R-002 (Gross Risk 16 — Critical; CE 25%) in the ICT Risk Register. Cyber incident cost monitoring has been added as a new gap from the updated register.

Requirement	Article	ISO 27001	Status	Current Position	Remediation Action	Priority	Target
Incident classification & detection	Art. 17	A.5.25, A.5.26	■ Partial	SIEM (Splunk) deployed; JIRA incident management; no DORA classification matrix; avg notification time 5.2h vs 4h threshold. R-002 (Gross 16 — Critical; CE 25%).	Implement DORA classification matrix per Art.17 criteria; train first-line teams; embed in SIEM playbooks.	Critical	Jul 2026
Major incident initial notification (4h)	Art. 19	A.5.26	✗ Missing	Manual BaFin reporting process; average notification time 5.2 hours — consistently breaches the 4-hour threshold; no BaFin MIDAS portal integration.	Build automated DORA reporting workflow; integrate with BaFin MIDAS portal; test notification quarterly.	Critical	Aug 2026
Intermediate & final incident reports	Art. 19	A.5.26	■ Partial	PIR process in JIRA; no 72h intermediate report process; not aligned to EBA/ESMA ITS format; submission timeline not tracked.	Adopt EBA ITS incident report templates; define intermediate report trigger; align final report to ITS format.	High	Sep–Oct 2026
Root cause analysis & lessons learned	Art. 17(6)	A.5.27	✓ Met	PIR mandatory for P1/P2; lessons-learned loop feeds into ICT Risk Register; operational.	Extend PIR/RCA to all DORA-classifiable incidents; formalise lessons-learned Risk Register update on each closure.	Medium	Sep 2026
Cyber incident cost monitoring	Art. 11(10)	A.5.29	✗ Missing	No formal tracking of direct or indirect ICT incident costs. Financial impact not included in incident reporting.	Implement incident cost tracking (direct: recovery, fines; indirect: lost revenue, reputational); integrate with Risk Register.	Medium	Jan 2027

Pillar 3 — Digital Operational Resilience Testing Articles 24–27

BAIT link: BAIT §6 (penetration testing), §7 (BCM testing) **MaRisk link:** MaRisk AT 7.3 (BCP testing)

This is the weakest pillar. Musterbank has never conducted a TLPT, which is mandatory given its size (Art.26 — Critical; R-004, Gross 16 — Critical; CE 0%). The BCP/DRP has not been tested for 18 months with 7 open remediation actions from 2024 outstanding and RTO/RPO unvalidated (Art.11 — Critical; R-015, Gross 25 — Critical; CE 0%). Both represent critical compliance gaps with potential for immediate BaFin supervisory action. Scenario-based testing and TPP dependency testing have been added from the updated Risk Register.

Requirement	Article	ISO 27001	Status	Current Position	Remediation Action	Priority	Target
Basic resilience testing programme	Art. 25	A.8.8	■ Partial	Quarterly VA scans; annual external pen test; DAST pipeline coverage 74%; 3 critical vulnerabilities open >14d. R-009 (Gross 16 — Critical; CE 50%).	Integrate DAST in CI/CD; formalise vulnerability remediation SLAs; close 3 criticals open >14d.	High	Aug 2026
Threat-Led Penetration Testing (TLPT)	Art. 26	A.8.8	✗ Missing	No TLPT ever conducted; Musterbank exceeds Art.26 thresholds; no TIBER-DE scope; no red-team provider contracted; BaFin not notified. R-004 (Gross 16 — Critical; CE 0%).	Scope TLPT per TIBER-DE; engage red-team provider via RFP; notify BaFin before commencement; target H2 2026.	Critical	Jan 2027
BCP/DRP testing & documentation	Art. 11	A.17.1	✗ Missing	BCP/DRP untested 18 months; 7 open 2024 remediation actions; RTO/RPO unvalidated; no documented test outcomes. R-015 (Gross 25 — Critical; CE 0%).	Tabletop Q3-2026; full DR test Q4-2026; close all 7 open actions; submit results to Risk Committee.	Critical	Oct 2026
Scenario-based resilience testing	Art. 25(3)	A.17.1	✗ Missing	No scenario-based exercises conducted. Testing limited to standard BCP and vulnerability scans.	Design and run 3 scenarios annually: ransomware + cloud outage; pandemic BCP; SWIFT fraud + simultaneous failure.	High	Jun 2027
Testing of critical ICT TPP dependencies	Art. 25(4)	A.15.1	■ Partial	Resilience testing excludes ICT TPP failure scenarios; AWS and Temenos not in scope; no contractual requirement for TPP participation.	Include AWS and Temenos failure scenarios in next DR test; contractually require TPP participation; document results.	High	Mar 2027

Pillar 4 — ICT Third-Party Risk Management Articles 28–44

BAIT link: BAIT §9 (outsourcing), §10 (cloud services), §12 (third-party risk) **MaRisk link:** MaRisk AT 9 (outsourcing), AT 9.2, AT 9.3 | §25b KWG

Third-party risk is the largest gap area by volume. CIF identification is now listed as a prerequisite — the Register of Information cannot be completed without it. AWS at 70% of critical ICT services represents a systemic concentration risk not formally reported to the board (R-003, Gross 25 — Critical; CE 25%). No exit plan exists for Temenos T24 — where a forced exit would take more than 24 months — or AWS (R-010, Gross 20 — Critical; CE 25%). New additions include a board-approved ICT third-party risk policy (Art.28(1)) and tightened Art.30 contractual clause coverage tracking.

Requirement	Article	ISO 27001	Status	Current Position	Remediation Action	Priority	Target
CIF identification	Art. 28 / EBA ITS	A.5.19	✗ Missing	No formal Critical or Important Function (CIF) mapping exercise conducted. CIF register does not exist. Register of Information cannot be completed without it.	CIF identification workshop; document CIF register; map ICT services and TPPs; board approval; prerequisite for Register of Information.	Critical	Sep 2026
Register of Information (ICT TPPs)	Art. 28	A.5.19	✗ Missing	Vendor register in Excel; not DORA Art.28 / EBA ITS RTS structured; missing CIF mapping, concentration data, sub-outsourcing chains. Dependent on CIF completion.	Rebuild per EBA ITS RTS template; complete for all critical/significant ICT TPPs; submit draft to BaFin.	Critical	Sep 2026
Art.30 contractual requirements	Art. 30	A.5.20	■ Partial	Standard contracts; Art.30 mandatory clauses at 60% coverage; audit rights, exit, DORA incident notification not systematically inserted.	Re-papering programme: Art.30 clauses in top 20 critical TPP contracts by Dec 2026.	High	Dec 2026
Exit plans for critical ICT TPPs	Art. 28(7)	A.5.20	✗ Missing	No exit plans for Temenos or AWS; Temenos exit >24 months; data portability never tested; no transition budget. R-010 (Gross 20 — Critical; CE 25%).	Draft exit plans for AWS, Temenos, ABACUS; test Temenos data portability; commission cost estimate; annual board review.	High	Dec 2026
ICT TPP concentration risk	Art. 29	A.5.19	■ Partial	AWS at 70% of critical ICT services — exceeds DORA Art.29 guidance; not formally reported to board; no diversification target set. R-003 (Gross 25 — Critical; CE 25%).	Formal concentration risk assessment per Art.29 EBA guidelines; board report; define diversification target (≤55%).	High	Oct 2026
Sub-outsourcing oversight	Art. 28(2)	A.5.19	■ Partial	Sub-outsourcing chain not fully mapped for AWS (CDN, DNS) or Finastra (clearing partners).	Map full sub-outsourcing chain for all critical ICT TPPs; include in Register of Information; contractual flow-down.	Medium	Jan 2027
Ongoing monitoring of ICT TPPs	Art. 28(6)	A.5.22	■ Partial	Annual vendor assessments only; no real-time SLA or security monitoring; audit rights rarely exercised.	Implement continuous TPP monitoring (security ratings, SLA dashboards); exercise audit rights annually for critical TPPs.	Medium	Jan 2027

Pillar 5 — Information Sharing Article 45

BAIT link: Not directly addressed in BAIT **MaRisk link:** MaRisk AT 7.2 (information security)

Information sharing under DORA Art.45 is voluntary but strongly encouraged by BaFin as a demonstration of proactive compliance posture. Musterbank has no formal sharing arrangements. FS-ISAC membership application is pending. The TIBER-DE threat intelligence feed has been onboarded but not operationalised into SIEM detection rules or control improvements (R-014, Gross 4 — Low; CE 50%). Threat intelligence operationalisation has been added as a new gap.

Requirement	Article	ISO 27001	Status	Current Position	Remediation Action	Priority	Target
Threat intelligence sharing	Art. 45	A.5.7	✗ Missing	No FS-ISAC membership; BaFin TIBER-DE feed onboarded but not operationalised into SIEM rules or control improvements. R-014 (Gross 4 — Low; CE 50%).	Apply for FS-ISAC membership; operationalise TIBER-DE feed; designate TI analyst; integrate into SIEM playbooks.	Medium	Dec 2026
Incident information sharing with peers	Art. 45	A.5.26	■ Partial	Ad-hoc sharing only; no NDA-backed bilateral sharing arrangement with peer German banks.	Establish ≥2 bilateral NDA-backed sharing agreements with peer German institutions; define scope and classification.	Low	Mar 2027
Threat intel operationalisation	Art. 45	A.5.7	■ Partial	TIBER-DE intelligence received but not translated into control updates or SIEM detection rules.	Define TI-to-control translation process; update SIEM rules monthly from intel; track TI-driven improvements.	Medium	Jan 2027

Additional Gaps — Governance, Culture & Controls

BAIT link: BAIT §2 (governance), §12 (third-party risk) **MaRisk link:** MaRisk AT 1 (governance), AT 9 (outsourcing)

The following requirements were identified through the ICT Risk Register review as material gaps not covered in the five standard DORA pillars. They include DORA management body accountability (Art.5), the digital operational resilience strategy (Art.6(7)), DORA training obligations (Art.13), NIS2 applicability, cryptographic key management (Art.9(2)), board-approved ICT third-party risk policy (Art.28(1)), and identity and access management controls. All are cross-referenced to the Risk Register where applicable.

Requirement	Article	ISO 27001	Status	Current Position	Remediation Action	Priority	Target
DORA governance — management body accountability	Art. 5	Cl. 5.1	■ Partial	IT risk governance exists; DORA-specific board mandate not defined; management body not briefed on Art.5 obligations; no DORA line item in board ToR.	Brief management board on Art.5 obligations; update Risk Committee Terms of Reference; establish DORA reporting line to board.	High	Sep 2026
Digital operational resilience strategy	Art. 6(7)	Cl. 6.1, 8.1	■ Partial	IT strategy exists; not structured as a DORA digital operational resilience strategy; DORA five pillars not explicitly addressed.	Develop standalone Digital Operational Resilience Strategy per Art.6(7); board approval; annual review cycle.	High	Dec 2026
DORA training & ICT risk culture	Art. 13	A.6.3	■ Partial	General security awareness training in place; no DORA-specific module; board has not received a DORA briefing.	Develop DORA training module for all staff; deliver board-level DORA briefing; track completion in compliance calendar.	High	Dec 2026
NIS2 alignment	NIS2 / DORA Art.1(2)	A.5.23	■ Partial	NIS2 applicability assessment not completed; BSI registration requirement not assessed; overlap with DORA not mapped.	Complete NIS2 applicability assessment; map overlap with DORA controls; notify BSI if registration required.	Medium	Dec 2026
Cryptographic controls & key management	Art. 9(2)	A.8.24	■ Partial	Encryption in place for data at rest and in transit; no formal key management policy; key rotation schedules undocumented; HSM not deployed for critical systems.	Document key management policy; define and automate key rotation schedules; evaluate HSM deployment for core banking and payment systems.	Medium	Dec 2026
ICT third-party risk appetite & policy	Art. 28(1)	A.5.19	✗ Missing	No board-approved ICT third-party risk appetite or policy. Vendor onboarding is ad hoc; no tiered risk classification for ICT TPPs at point of engagement.	Draft ICT third-party risk policy; define tiered classification (Critical / Significant / Non-critical); board approval; integrate into procurement process.	High	Oct 2026
Identity & access management (IAM) controls	Art. 9	A.5.15, A.5.16	■ Partial	Active Directory in place; CyberArk PAM at 88% coverage; 2 shared admin accounts outstanding; privileged access recertification at 85% completion. R-008 (Gross 15 — High; CE 75%).	Complete PAM to 100%; eliminate 2 remaining shared admin accounts; complete access recertification 100%; quarterly review cycle.	High	Aug 2026

Remediation Roadmap — Priority Actions

The following critical and high-priority actions are recommended for immediate attention. These address the most significant DORA compliance gaps and areas of BaFin supervisory focus in 2026–2027. CIF identification and ICT risk appetite approval are prerequisites for multiple downstream actions and should be treated as the critical path items. All actions are cross-referenced to the ICT Risk Register where applicable.

Priority	Article	Action	Owner	Target	Risk Ref
Critical	Art. 28 / EBA ITS	Complete CIF identification — prerequisite for Register of Information and Art.29 concentration risk reporting	CRO / Compliance	Sep 2026	—
Critical	Art. 6(8)	Draft and board-approve ICT risk appetite & tolerance statement; cascade to Risk Register KRI thresholds	CRO	Sep 2026	All risks
Critical	Art. 17, 19	Implement DORA incident classification matrix; build automated 4h BaFin notification workflow (MIDAS portal)	CRO / CISO	Jul–Aug 2026	R-002
Critical	Art. 11	BCP/DRP tabletop Q3-2026; full DR test T24 & ABACUS Q4-2026; close 7 outstanding 2024 actions; validate RTO ≤4h / RPO ≤1h	CISO / IT Ops	Oct 2026	R-015
Critical	Art. 26	Scope and initiate TLPT per TIBER-DE methodology; engage red-team provider via RFP; notify BaFin before commencement	CISO	Jan 2027	R-004
Critical	Art. 28	Rebuild Register of Information per EBA ITS RTS format (after CIF completion); submit draft to BaFin	CTO / Procurement	Sep 2026	R-003, R-010
High	Art. 5–6	Board approval of ICT risk management framework; brief management body on Art.5 obligations; update Risk Committee ToR	CEO / CRO	Sep 2026	—
High	Art. 28(1)	Draft and board-approve ICT third-party risk policy; define tiered TPP classification; integrate into procurement	CRO / Procurement	Oct 2026	—
High	Art. 30	Re-papering programme: Art.30 clauses in top 20 critical TPP contracts; track coverage to 100%	General Counsel	Dec 2026	R-003, R-010
High	Art. 28(7)	Draft exit plans for AWS, Temenos T24, ABACUS; test Temenos data portability; commission transition cost estimates	CTO	Dec 2026	R-010
High	Art. 29	Formal AWS concentration risk assessment; board report; define diversification target (≤55%); include in ICT risk appetite	CRO / CTO	Oct 2026	R-003
High	Art. 25	Integrate DAST into CI/CD pipeline; formalise vulnerability remediation SLAs; close 3 criticals open >14 days	Head of Digital	Aug 2026	R-009
High	Art. 13	Develop DORA training module for all staff; deliver board-level DORA briefing session; track completion	HR / CISO	Dec 2026	—
Medium	Art. 45	Apply for FS-ISAC membership; operationalise TIBER-DE feed into SIEM; designate TI analyst	CISO	Dec 2026	R-014
Medium	Art. 11(10)	Implement ICT incident cost tracking; include in incident reports and Risk Register	CFO / CRO	Jan 2027	—
Medium	Art. 9(2)	Document key management policy; define key rotation schedules; evaluate HSM for core banking and payments	CISO	Dec 2026	—